راهنمای IP برای مدیریت تقلب

آشنایی کاربردی با IP

در شبکه‌های مخابراتی

مفاهیم شبکه امنیت و VPN

توضیح گام به گام مفاهیم با مثال‌های مخابراتی

شناخت شواهد و محدودیت‌های تشخیص تقلب

با تأکید بر کاربرد مفاهیم در بررسی تقلب

نسخه ویژه همکاران مدیریت تقلب FMS

IP | TELECOM | SECURITY | VPN

فهرست مطالب

عنوان فصل و بخش	صفحه
راهنمای مطالعه و چکیده کاربردی	4
فصل اول IP چیست و ارتباط اینترنتی چگونه شکل می‌گیرد	6
۱.۱. از یک پیام تا چند بسته اطلاعات	6
۱.۲. برای بازشدن یک سرویس چه اجزایی همکاری می‌کنند	7
۱.۳. کدام اطلاعات داخل بسته برای ما مهم است	8
۱.۴. آدرس IP شبکه محلی و ماسک	9
۱.۵. چرا یک IP عمومی ممکن است متعلق به چند مشترک باشد	10
۱.۶. IPv6 چه چیزی را تغییر می‌دهد	11
۱.۷. روترها مسیر را چگونه یاد می‌گیرند	11
فصل دوم IP در شبکه مخابراتی چه نقشی دارد	13
۲.۱. MPLS جداسازی سرویس‌ها روی شبکه مشترک	13
۲.۲. کیفیت سرویس چرا سرعت دانلود کافی نیست	14
۲.۳. تماس IP برقراری تماس با عبور صدا فرق دارد	15
۲.۴. حرکت مشترک و مسیر داده در 4G و 5G	16
فصل سوم امنیت و تقلب در بستر IP تفسیر نشانه‌ها در FMS	18
۳.۱. آدرس IP چقدر به شناسایی کمک می‌کند	18
۳.۲. جعل مبدأ و حمله منع سرویس ترافیک زیاد همیشه حمله نیست	19
۳.۳. مرد میانی در شبکه محلی چرا آدرس درست کافی نیست	21
۳.۴. ربایش مسیر و نشت مسیر مشکل همیشه داخل سازمان نیست	21

عنوان فصل و بخش	صفحه
۳.۵. بازرسی ترافیک تخلف و حدود حریم خصوصی	22
فصل چهارم VPN و حدود حفاظت ارتباط	24
۴.۱. سه پرسش اصلی درباره امنیت VPN	24
۴.۲. IPsec به زبان ساده توافق اولیه و انتقال امن داده	25
۴.۳. تفاوت گزینه‌های رایج VPN بدون ورود به تنظیمات پیچیده	26
۴.۴. همه ترافیک وارد تونل می‌شود مسیر کامل مسیر تفکیکی و نشت	27
۴.۵. چرا داده کوچک می‌رود ولی فایل بزرگ متوقف می‌شود	27
فصل پنجم فناوری‌های جدیدتر چه چیزی را بهتر می‌کنند	29
۵.۱. فناوری SRv6 هدایت ترافیک از نقاط انتخاب‌شده	29
۵.۲. فناوری SD-WAN انتخاب بهتر میان چند اتصال	30
۵.۳. اعتماد صفر ZTNA و SASE دسترسی دقیق‌تر	30
پیوست راهنمای تحلیل رخداد در مدیریت تقلب	32
۱. از کیفیت لاگ تا تصمیم قابل دفاع	32
۲. چهار سناریوی بررسی تقلب	32
۳. الگوی ثبت پرونده و واژه‌نامه	35
منابع و یادداشت ارجاع	37

راهنمای مطالعه و چکیده کاربردی

این گزارش برای همکاران **سامانه مدیریت تقلب یا FMS، مخفف Fraud Management System** تنظیم شده است. هدف این است که هنگام بررسی هشدار، سابقه ارتباط و گزارش سامانه‌ها، معنای اطلاعات را بهتر بفهمید و درباره احتمال تقلب نتیجه دقیق‌تری بگیرید. متن از پایه شروع می‌شود، اصطلاحات را در محل استفاده توضیح می‌دهد و جزئیات ضروری برای تحلیل را نگه می‌دارد.

IP یا «پروتکل اینترنت»، قواعد آدرس‌دهی و جابه‌جایی بسته‌های اطلاعات در شبکه را مشخص می‌کند. بسیاری از تماس‌ها، پیام‌ها و درخواست‌های اینترنتی از همین بستر عبور می‌کنند. در FMS، اطلاعاتی مانند IP، زمان، حجم ارتباط و مقصد می‌توانند به شناخت الگو کمک کنند؛ اما هیچ‌کدام به‌تنهایی هویت فرد یا وقوع تقلب را ثابت نمی‌کنند. برای مثال، چند مشترک ممکن است به‌دلیل اشتراک آدرس در شبکه اپراتور یا CGNAT یک IP عمومی مشترک داشته باشند.

ساختار گزارش در پنج فصل تنظیم شده است:

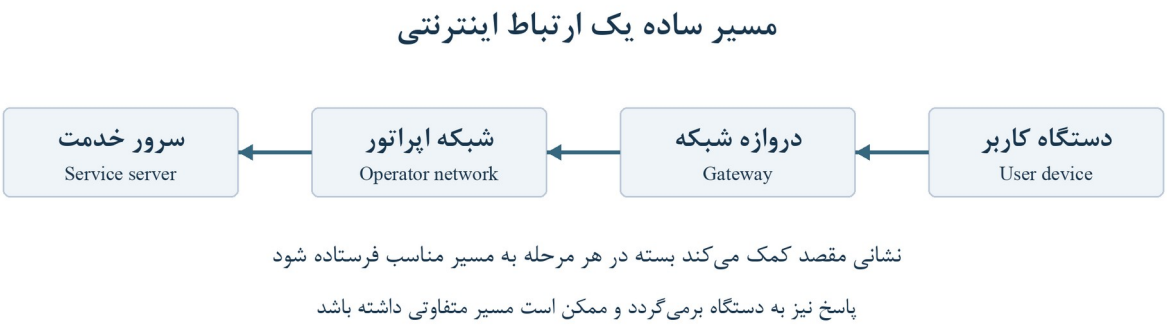
- **فصل اول:** بسته، آدرس، پورت، شبکه داخلی، IPv6 ،IPv4 و مسیریابی را توضیح می‌دهد؛ این مفاهیم پایه خواندن گزارش‌ها هستند.
- **فصل دوم:** کاربرد آن‌ها را در شبکه اپراتور، اینترنت همراه و تماس اینترنتی نشان می‌دهد تا محل تولید اطلاعات روشن‌تر شود.
- **فصل سوم:** سوءاستفاده‌ها، حملات و حدود شواهد شبکه را بررسی می‌کند؛ هشدار مشکوک با اثبات تخلف یکسان نیست.
- **فصل چهارم:** توضیح می‌دهد VPN و رمزنگاری چه چیزی را تغییر می‌دهند و چرا استفاده از VPN به‌خودی‌خود تقلب محسوب نمی‌شود.
- **فصل پنجم:** فناوری‌های جدیدتر و اثر آن‌ها بر تفسیر مسیر، آدرس و دسترسی را معرفی می‌کند.

پس از فصل‌ها، بخش کاربردی به روند بررسی و اطلاعات لازم برای پیگیری پرونده کمک می‌کند. برای مطالعه نخست، فصل‌ها را به‌ترتیب بخوانید؛ در مراجعه بعدی از مثال‌ها و جدول‌ها شروع کنید. لازم نیست نام تمام فناوری‌ها را حفظ کنید. مهم‌تر این است که بدانید هر داده از کجا آمده، چه چیزی را نشان می‌دهد و چه چیزی را نمی‌توان از آن نتیجه گرفت.

در پایان باید بتوانید میان «آدرس دیده‌شده»، «حساب مشترک» و «شخص استفاده‌کننده» تفاوت بگذارید. برای تطبیق رویداد در CGNAT، تنها IP عمومی کافی نیست؛ زمان دقیق با منطقه زمانی و معمولاً پورت و نوع پروتکل نیز لازم است. تحلیل معتبر از کنار هم گذاشتن شواهد، کنترل خطای داده و رعایت مجوز دسترسی به دست می‌آید. یک نشانه می‌تواند آغاز بررسی باشد؛ نتیجه پرونده به شواهد کافی و روند مصوب سازمان نیاز دارد.

فصل اول IP چیست و ارتباط اینترنتی چگونه شکل می‌گیرد

۱.۱. از یک پیام تا چند بسته اطلاعات



شکل ۱ ـ مسیر ساده بسته از دستگاه تا سرور؛ پاسخ می‌تواند از مسیر دیگری برگردد.

وقتی مشترک صفحه‌ای را باز می‌کند، فایل می‌فرستد یا تماس اینترنتی دارد، داده در قالب واحدهای کوچک‌تری به نام **بسته** جابه‌جا می‌شود. **پروتکل اینترنت یا IP** قواعد آدرس‌دهی و رساندن این بسته‌ها میان شبکه‌ها را مشخص می‌کند. در مدیریت تقلب، شناخت IP کمک می‌کند ارتباط میان رخدادها را بررسی کنیم؛ اما آدرس شبکه را نباید معادل هویت شخص بدانیم.

هر بسته را می‌توان شبیه یک مرسوله دانست: نشانی مبدأ و مقصد دارد و از چند مرکز توزیع عبور می‌کند. **روتر** دستگاهی است که گام بعدی بسته را انتخاب می‌کند؛ معمولاً تصمیم می‌گیرد بسته را به کدام همسایه تحویل دهد، نه اینکه کل مسیر را از ابتدا تعیین کند.

در تلفن سنتی، برای یک تماس ظرفیت مشخصی در مسیر اختصاص می‌یافت. در شبکه بسته‌ای، تماس‌ها، دانلودها و پیام‌ها از ظرفیت مشترک استفاده می‌کنند. این اشتراک بهره‌وری را بالا می‌برد، اما وقتی تقاضا بیش از ظرفیت شود، صف تشکیل می‌شود و ممکن است بسته‌ها دیر برسند یا حذف شوند.

خود IP تضمین نمی‌کند همه بسته‌ها برسند یا به ترتیب برسند. جبران خطا، در صورت نیاز، به پروتکل‌های دیگر یا نرم‌افزار واگذار می‌شود. اگر لینکی قطع شود، شبکه می‌تواند مسیر جایگزین پیدا کند؛ ولی تشخیص خرابی و فعال‌شدن مسیر جدید زمان می‌برد. بنابراین «وجود مسیر پشتیبان» به معنی «نبود هیچ وقفه‌ای» نیست. [1]

۱.۲. برای بازشدن یک سرویس چه اجزایی همکاری می‌کنند

در بازکردن یک وب‌سایت، مرورگر درخواست را می‌سازد؛ پروتکل انتقال، تبادل داده میان نرم‌افزارها را مدیریت می‌کند؛ IP بسته را میان شبکه‌ها می‌رساند؛ و کابل، فیبر یا امواج رادیویی آن را روی هر بخش مسیر حمل می‌کنند. این اجزا با همکاری هم ارتباط را شکل می‌دهند.

سامانه نام دامنه یا DNS نامی مانند example.com را به اطلاعاتی از جمله آدرس IP تبدیل می‌کند. DNS شبیه دفتر راهنمای نشانی‌هاست. اگر DNS مشکل داشته باشد، ممکن است اینترنت مشترک برقرار باشد، اما سایت با نام باز نشود. برعکس، دریافت پاسخ DNS ثابت نمی‌کند خود وب‌سایت هم در دسترس است.

دروازه پیش‌فرض یا Default Gateway معمولاً همان روتر خروجی شبکه محلی است. دستگاه برای رسیدن به مقصدی بیرون از شبکه خودش، بسته را به این دروازه می‌سپارد. اشتباه‌بودن تنظیم دروازه می‌تواند ارتباط داخلی را سالم نگه دارد ولی دسترسی بیرونی را قطع کند.

پروتکل کنترل انتقال یا TCP داده‌های یک ارتباط را مرتب می‌کند و در صورت گم‌شدن، برای ارسال دوباره اقدام می‌کند. این ویژگی برای دریافت فایل مفید است؛ اما انتظار برای داده گم‌شده می‌تواند تأخیر ایجاد کند. **پروتکل دیتاگرام کاربر یا UDP** چنین تضمینی را خودش ارائه نمی‌کند. در تماس زنده، رسیدن سریع بسته‌های جدید اغلب مهم‌تر از بازیابی صدایی است که زمان پخش آن گذشته است؛ به همین دلیل UDP در این کاربرد رایج است. نرم‌افزار همچنان باید کیفیت و ازدحام را مدیریت کند.

پورت شماره‌ای برای تشخیص سرویس یا ارتباط در یک دستگاه است. IP را می‌توان نشانی ساختمان و پورت را شماره واحد دانست. شماره پورت به‌تنهایی نوع واقعی برنامه یا سالم‌بودن آن را اثبات نمی‌کند.

پروتکل پیام‌های کنترلی اینترنت یا ICMP برای اعلام بعضی خطاها و کمک به عیب‌یابی به کار می‌رود. ابزار Ping معمولاً از آن استفاده می‌کند. پاسخ Ping فقط دسترسی در حد همان آزمون را نشان می‌دهد؛ بازشدن سرویس را تضمین نمی‌کند. نبود پاسخ نیز ممکن است ناشی از محدودیت یا فیلتر ICMP باشد، نه قطع کامل ارتباط.

۱.۳. کدام اطلاعات داخل بسته برای ما مهم است

بسته دارای **سربرگ** است؛ بخشی که اطلاعات راهبری را پیش از داده اصلی نگه می‌دارد. در نسخه چهار IP یا **IPv4**، سربرگ معمولاً ۲۰ بایت است. برای خواندن گزارش‌ها و تحلیل اولیه، این موارد کاربرد بیشتری دارند: [1]

- **آدرس مبدأ و مقصد:** بسته ظاهراً از کجا آمده و به کجا می‌رود؟ آدرس مبدأ به‌تنهایی هویت فرستنده را ثابت نمی‌کند و در برخی شرایط جعل‌پذیر است.
- **نوع پروتکل بعدی:** مشخص می‌کند محتوای بسته مثلاً TCP، UDP یا ICMP است. دو ارتباط با یک مقصد می‌توانند رفتار کاملاً متفاوتی داشته باشند.
- **طول بسته:** اندازه بسته بر عبور از مسیر و تونل‌ها اثر دارد. **حداکثر واحد انتقال یا MTU** اندازه بسته قابل حمل بدون قطعه‌بندی در یک رابط را محدود می‌کند. در بسیاری از شبکه‌های Ethernet مقدار ۱۵۰۰ بایت رایج است، ولی همگانی نیست.
- **عمر بسته یا TTL:** با عبور از روترها کاهش می‌یابد تا بسته در یک حلقه بی‌پایان نچرخد. ابزار Traceroute از همین ویژگی برای بررسی گام‌های مسیر استفاده می‌کند. بعضی گام‌ها به دلیل محدودیت پاسخ دیده نمی‌شوند.
- **نشان کیفیت سرویس یا DSCP:** به تجهیزات کمک می‌کند بسته را در کلاس مناسب قرار دهند؛ مثلاً صوت را از دانلود جدا کنند. این نشان به‌تنهایی ظرفیت رزرو نمی‌کند و اجازه ویژه‌ای به کاربر نمی‌دهد.

اگر بسته از ظرفیت اندازه مسیر بزرگ‌تر باشد، ممکن است نیاز به کوچک‌شدن یا تکه‌تکه‌شدن داشته باشد. بسته به نسخه IP و تنظیمات، نتیجه می‌تواند دریافت پیام خطا یا حذف بسته باشد. نمونه ملموس، اتصالی است که صفحه‌های کوچک را باز می‌کند ولی انتقال فایل روی VPN در آن متوقف می‌شود. این نشانه می‌تواند با MTU مرتبط باشد، اما برای تشخیص قطعی باید شواهد بیشتری جمع کرد.

۱.۴. آدرس IP شبکه محلی و ماسک

آدرس IPv4 مانند 192.168.1.50 از چهار عدد صفر تا ۲۵۵ تشکیل می‌شود. دستگاه علاوه بر آدرس خودش، باید بداند چه مقصدهایی در همان شبکه محلی هستند. این مرز با **ماسک زیرشبکه یا Subnet Mask** مشخص می‌شود.

در مثال 192.168.1.50/24، عبارت 24/ یعنی ۲۴ بیت اول بخش شبکه است؛ معادل ماسک 255.255.255.0. در این مثال، دستگاه‌های 192.168.1.1 تا 192.168.1.254 می‌توانند در یک زیرشبکه معمول قرار بگیرند. آدرس 0. شناسه شبکه و 255. آدرس ارسال همگانی آن است. مقصدی مانند 192.168.2.10 بیرون این زیرشبکه قرار می‌گیرد و معمولاً باید از روتر قابل دسترس باشد.

پس 24/ سرعت یا تعداد کاربران متصل را نشان نمی‌دهد؛ اندازه محدوده آدرس را مشخص می‌کند. روش نوشتن آدرس همراه طول پیشوند، **آدرس‌دهی بدون کلاس یا CIDR** نام دارد. بعضی پیشوندها، مانند 31/ در اتصال نقطه‌به‌نقطه، قواعد تخصیص متفاوتی دارند؛ قاعده «کل آدرس‌ها منهای دو» را نباید به همه حالت‌ها تعمیم داد. [3]

آدرس عمومی می‌تواند، در صورت وجود مسیر و مجوز دسترسی، در اینترنت عمومی استفاده شود. **آدرس خصوصی** برای مصرف داخل شبکه است و مستقیماً به‌عنوان مسیر عمومی اینترنت منتشر نمی‌شود. سه محدوده خصوصی اصلی عبارت‌اند از: [4]

جدول ۱ ـ آدرس IP شبکه محلی و ماسک

محدوده خصوصی	نمونه آدرس	کاربرد متداول
10.0.0.0/8	10.20.3.15	شبکه داخلی سازمان یا اپراتور
172.16.0.0/12	172.20.5.10	شبکه داخلی و مرکز داده؛ فقط بازه ۱۷۲٫۱۶ تا ۱۷۲٫۳۱ خصوصی است
192.168.0.0/16	192.168.1.50	شبکه خانگی، شعب و شرکت‌ها

دو شرکت جدا می‌توانند هر دو از 192.168.1.0/24 استفاده کنند. بنابراین مشاهده یک IP خصوصی یکسان در دو گزارش، لزوماً نشانه دستگاه مشترک نیست؛ باید معلوم باشد هر گزارش متعلق به کدام شبکه است. خصوصی‌بودن آدرس نیز به معنی امن‌بودن دستگاه نیست.

۱.۵. چرا یک IP عمومی ممکن است متعلق به چند مشترک باشد

IPv4 در مجموع حدود ۴،۳ میلیارد آدرس دارد و همه آن‌ها نیز برای استفاده عمومی آزاد نیستند. محدودیت این فضا باعث شده اشتراک آدرس بسیار رایج شود. در خانه، **ترجمه آدرس شبکه یا NAT** اجازه می‌دهد چند دستگاه داخلی از یک آدرس بیرونی استفاده کنند. معمولاً شماره پورت هم در نگاشت ارتباط‌ها نقش دارد.

اپراتور نیز می‌تواند این کار را در مقیاس بزرگ انجام دهد. نام آن **ترجمه آدرس در مقیاس اپراتور یا CGNAT** است. در این حالت چندین مشترک هم‌زمان پشت یک IP عمومی دیده می‌شوند. محدوده 100.64.0.0/10 برای فضای اشتراکی این کاربرد تعریف شده و با سه محدوده خصوصی جدول قبل تفاوت دارد. استفاده دقیق از آدرس‌ها و تعداد مشترکان پشت هر IP به طراحی اپراتور وابسته است. [6] [5]

مثال: سایت مقصد، دو اتصال را از IP عمومی یکسان، ولی با پورت‌های مبدأ متفاوت می‌بیند. این دو اتصال ممکن است مربوط به دو مشترک کاملاً جدا باشند. بنابراین مسدودکردن آن IP می‌تواند کاربران بی‌ارتباط را هم متأثر کند؛ مثلاً با کپچا یا محدودیت ورود مواجه شوند.

برای بررسی اینکه یک اتصال در زمان مشخص به کدام اشتراک مربوط بوده، معمولاً باید **IP عمومی، پورت مبدأ عمومی، پروتکل، زمان دقیق و منطقه زمانی** با سوابق معتبر ترجمه آدرس و نشست مشترک تطبیق داده شوند. بسته به طراحی ثبت وقایع، اطلاعات بیشتری نیز لازم می‌شود. اختلاف ساعت سامانه‌ها یا نبود پورت می‌تواند نتیجه را نامطمئن کند.

حتی تعیین اشتراک به معنی شناسایی قطعی شخص انجام‌دهنده نیست؛ اتصال ممکن است میان افراد، دستگاه‌ها یا یک VPN مشترک باشد. این تمایز برای بررسی رخداد و هرگونه انتساب مسئولیت ضروری است. دسترسی و نگه‌داری سوابق نیز باید محدود و مطابق مقررات باشد.

۱.۶. IPv6 چه چیزی را تغییر می‌دهد

نسخه ششم IP یا **IPv6** فضای آدرس بسیار بزرگ‌تری دارد. آدرسی مانند 2001:db8::25 از قالب متفاوتی استفاده می‌کند؛ این نمونه مخصوص مستندسازی است. هدف اصلی IPv6 رفع محدودیت آدرس و امکان توسعه بهتر شبکه است، نه تضمین سرعت بیشتر یا امنیت خودکار. [2]

در دوره گذار، بسیاری از شبکه‌ها هم‌زمان IPv4 و IPv6 دارند؛ این حالت **پشته دوگانه یا Dual Stack** نامیده می‌شود. یک دستگاه می‌تواند هم‌زمان چند آدرس داشته باشد و آدرس IPv6 موقت آن برای حفظ حریم خصوصی تغییر کند. در نتیجه چند IP متفاوت لزوماً به معنی چند شخص یا تقلب نیست؛ تطبیق با زمان و اطلاعات مجاز نشست لازم است.

در IPv6، روتر میانی بسته بزرگ را تکه‌تکه نمی‌کند. پیام کنترلی «بسته بیش از اندازه بزرگ است» به مبدأ کمک می‌کند اندازه مناسب را انتخاب کند. مسدودکردن بی‌قیدوشرط ICMPv6 می‌تواند این سازوکار و بعضی کارکردهای ضروری دیگر را مختل کند. [7]

IPv6 ترافیک را خودکار رمزنگاری نمی‌کند. فایروال، کنترل دسترسی و پایش باید برای آن هم برقرار باشد. فعال‌بودن IPv6 در کنار کنترل‌های صرفاً IPv4 می‌تواند نقطه کور ایجاد کند.

۱.۷. روترها مسیر را چگونه یاد می‌گیرند

روتر با استفاده از **جدول مسیر** تصمیم می‌گیرد بسته هر محدوده را به کدام سمت بفرستد. بعضی مسیرها دستی تعریف می‌شوند و بعضی را تجهیزات خودکار از هم یاد می‌گیرند. **مسیریابی داخلی** ارتباط درون شبکه یک سازمان یا اپراتور را مدیریت می‌کند. پروتکل مسیریابی داخلی **OSPF** اطلاعات مسیر و هزینه لینک‌ها را مبادله می‌کند تا مسیر مناسب و در صورت امکان جایگزین انتخاب شود.

میان شبکه‌های مستقل، مانند یک اپراتور و ارائه‌دهنده اینترنت بالادستی، **پروتکل دروازه مرزی یا BGP** به کار می‌رود. هر شبکه مستقل، شناسه‌ای دارد که **ASN** نامیده می‌شود. BGP مشخص می‌کند چه محدوده‌هایی از

طریق کدام شبکه‌ها قابل دسترس‌اند و انتخاب آن به سیاست‌های ارتباطی و تجاری نیز وابسته است. همیشه کوتاه‌ترین مسیر جغرافیایی یا کم‌تأخیرترین مسیر انتخاب نمی‌شود. [8]

در تحلیل تقلب، مسیر شبکه یا مالک محدوده IP با محل دقیق شخص یکی نیست. پایگاه مکان‌یابی IP ممکن است محل ثبت اپراتور، نقطه خروج ترافیک یا اطلاعات قدیمی را نشان دهد. تغییر مسیر و استفاده از VPN نیز تصویر را تغییر می‌دهند. «دو کشور متفاوت در گزارش IP» می‌تواند نشانه نیازمند بررسی باشد، اما به‌تنهایی سفر واقعی یا تقلب را ثابت نمی‌کند.

فصل دوم IP در شبکه مخابراتی چه نقشی دارد

شبکه مخابراتی امروز اینترنت، صوت، تصویر و ارتباط سازمان‌ها را روی زیرساخت‌های مشترک منتقل می‌کند. برای تحلیل تقلب باید بدانیم هر داده از کدام سرویس و کدام نقطه شبکه ثبت شده است. یک IP در گزارش وب، یک شناسه در هسته همراه و یک شماره در گزارش تماس، الزاماً یک نوع مدرک نیستند.

۲.۱. MPLS جداسازی سرویس‌ها روی شبکه مشترک

سوئیچینگ چندپروتکلی مبتنی بر برچسب یا MPLS روشی است که در آن بسته‌ها با برچسب‌های تعیین‌شده در شبکه هدایت می‌شوند. تصور کنید اپراتور یک شبکه جاده‌ای مشترک دارد، اما برای هر سرویس مسیرها و قواعد مشخصی تعریف کرده است. برچسب‌ها به تجهیزات می‌گویند بسته در کدام مسیر و سرویس منطقی جابه‌جا شود.

برای مثال، شعب یک بانک و شعب یک شرکت دیگر می‌توانند از زیرساخت فیزیکی یک اپراتور استفاده کنند، ولی مسیرهای منطقی و اطلاعات مسیریابی آن‌ها از هم جدا باشد. این کاربرد در خدمات **شبکه خصوصی مجازی لایه سه یا L3VPN** رایج است. MPLS ابزارهایی برای مدیریت مسیر و بازیابی پس از خرابی نیز فراهم می‌کند؛ دلیل استفاده از آن صرفاً «کندبودن IP» نیست. [10]

نکته امنیتی اصلی این است که **جداسازی با رمزنگاری فرق دارد**. سرویس MPLS VPN به‌خودی‌خود محتوای بسته را رمز نمی‌کند. برای داده حساس، حفاظت در خود برنامه، مانند HTTPS، یا تونل رمزنگاری‌شده باید بر اساس نیاز بررسی شود. همچنین داخلی‌بودن یک ارتباط یا عبور آن از شبکه خصوصی، سالم‌بودن تراکنش یا نبود تقلب را اثبات نمی‌کند.

۲.۲. کیفیت سرویس چرا سرعت دانلود کافی نیست

کیفیت سرویس یا QoS مجموعه روش‌هایی برای مدیریت رفتار ترافیک، به‌ویژه هنگام ازدحام، است. شبکه می‌تواند صوت زنده را زودتر از دانلود فایل ارسال کند؛ چون چند لحظه تأخیر برای دانلود معمولاً قابل‌تحمل‌تر از مکث در مکالمه است. برای توصیف کیفیت، این شاخص‌ها را جداگانه ببینیم:

جدول ۲ ــ کیفیت سرویس چرا سرعت دانلود کافی نیست

شاخص	معنی ساده	نشانه قابل مشاهده
ظرفیت و توان عملیاتی	ظرفیت لینک با نرخ مفید واقعاً دریافت‌شده یکی نیست	دانلود کند یا نرسیدن نرخ مفید به مقدار مورد انتظار
تأخیر	مدت رسیدن داده؛ رفت‌وبرگشت با تأخیر یک‌طرفه متفاوت است	مکث میان حرف‌زدن و شنیدن پاسخ
نوسان تأخیر یا Jitter	بسته‌ها با فاصله‌های زمانی نامنظم می‌رسند	صدای ناپیوسته یا نیاز به بافر بیشتر
حذف بسته یا Packet Loss	بخشی از بسته‌ها به مقصد نمی‌رسند	حذف بخشی از صدا، افت تصویر یا ارسال دوباره داده

برای صوت، تأخیر یک‌طرفه حدود ۱۵۰ میلی‌ثانیه هدف رایجی است؛ بااین‌حال مرز کیفیت همه سرویس‌ها یکسان نیست. روش کدگذاری صدا یا کدک، حافظه موقت تنظیم پخش یا بافر، مسیر و الگوی حذف نیز اثر دارند. یک درصد حذف پراکنده ممکن است اثر متفاوتی از حذف چند بسته پشت‌سرهم داشته باشد.

در روش رایج **خدمات متمایز یا DiffServ**، ترافیک در چند کلاس قرار می‌گیرد و صف‌ها مطابق سیاست سرویس می‌گیرند. نشان DSCP به تشخیص کلاس کمک می‌کند، اما کیفیت فقط با نوشتن یک عدد روی بسته تضمین نمی‌شود. ظرفیت کافی، اعمال درست سیاست و هماهنگی بخش‌های مسیر لازم است. [9]

برای مدیریت تقلب، افزایش حجم ترافیک یا افت کیفیت می‌تواند یک علامت اولیه باشد، اما علت‌های عادی هم دارد؛ مثلاً به‌روزرسانی نرم‌افزار، پخش ویدئو یا ازدحام. نتیجه‌گیری به مقایسه با الگوی معمول مشترک، نوع سرویس و شواهد دیگر نیاز دارد. «مصرف زیاد» و «مصرف متقلبانه» یک مفهوم نیستند.

۲.۳. تماس IP برقراری تماس با عبور صدا فرق دارد

صوت بر بستر IP یا VoIP دو بخش اصلی دارد. نخست **سیگنالینگ** است: پیام‌هایی برای شروع تماس، زنگ‌خوردن، پاسخ و پایان. دوم **رسانه** است: بسته‌هایی که خود صدا یا تصویر را حمل می‌کنند. این دو بخش ممکن است مسیرها و تجهیزات متفاوتی داشته باشند.

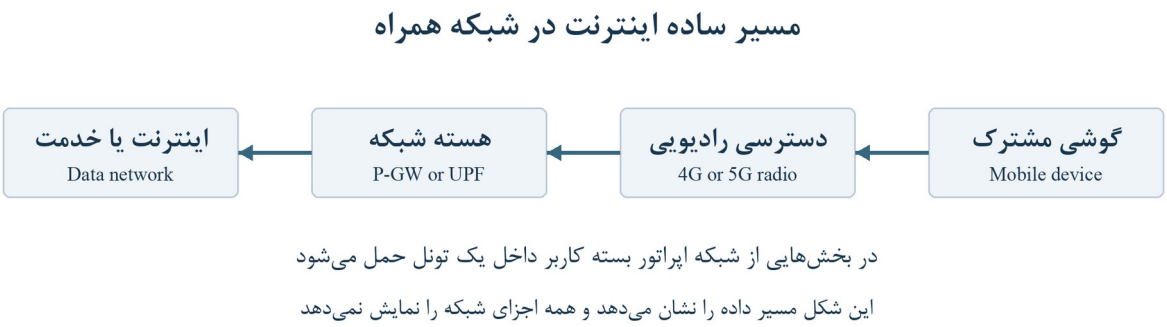
پروتکل آغاز نشست یا SIP از پروتکل‌های رایج سیگنالینگ است. **پروتکل انتقال بلادرنگ یا RTP** نیز معمولاً صدا را روی UDP حمل می‌کند و شماره توالی و زمان‌مهر دارد تا گیرنده بتواند پخش را مدیریت کند. RTP عادی به‌خودی‌خود رمزنگاری نمی‌کند؛ حفاظت رسانه به سازوکار جداگانه نیاز دارد.

مثال: تلفن مقصد زنگ می‌خورد و تماس پاسخ داده می‌شود، اما صدا یک‌طرفه است. در این وضعیت، بخشی از سیگنالینگ موفق بوده، ولی این موفقیت سالم‌بودن مسیر رسانه را ثابت نمی‌کند. آدرس رسانه، ترجمه آدرس، فایروال، مسیر رفت‌وبرگشت یا تجهیزات واسط می‌توانند در مشکل نقش داشته باشند. در مقابل، برقرارنشدن تماس از ابتدا مسیر بررسی متفاوتی دارد.

در شبکه همراه، **زیرسامانه چندرسانه‌ای IP یا IMS** بستر کنترل خدماتی مانند تماس اپراتوری است. **صوت بر بستر LTE یا VoLTE** به تماس اپراتوری در فناوری LTE نسل چهارم و **صوت بر بستر رادیوی جدید یا VoNR** به تماس در نسل پنجم مربوط می‌شود. این خدمات با تماس پیام‌رسان یکسان نیستند. [13]

برای تحلیل تقلب تلفنی، **شماره تماس‌گیرنده نمایش‌داده‌شده یا Caller ID** را نباید مدرک قطعی هویت دانست؛ اعتبار آن به نحوه ورود تماس، کنترل‌های شبکه و امکان جعل وابسته است. **رکورد جزئیات تماس یا CDR** نیز باید با زمان، مسیر ورود و اطلاعات معتبر مشترک تطبیق داده شود. IP یک تجهیز واسط ممکن است متعلق به دروازه یا مرکز تماس باشد، نه گوشی شخص تماس‌گیرنده.

۲.۴. حرکت مشترک و مسیر داده در 4G و 5G



شکل ۲ ـ مسیر ساده داده در شبکه همراه؛ هسته شبکه بین دسترسی رادیویی و خدمت قرار دارد.

در اتصال همراه، گوشی با حرکت کاربر از پوشش یک سلول به سلول دیگر می‌رود. **تحویل ارتباط یا Handover** فرایند جابه‌جایی اتصال رادیویی است. شبکه تلاش می‌کند نشست کاربر ادامه پیدا کند و در بسیاری از جابه‌جایی‌های معمول، آدرس نشست حفظ می‌شود. این کار نیازمند هماهنگی است و ممکن است افت کوتاه، حذف یا بی‌ترتیبی بسته رخ دهد.

برای حمل داده مشترک در بخش‌هایی از شبکه، از **پروتکل تونل‌زنی شبکه همراه، بخش کاربر یا GTP-U** استفاده می‌شود. بسته IP کاربر در پوشش یک بسته دیگر قرار می‌گیرد تا تجهیزات شبکه آن را به نقطه مناسب برسانند. شناسه تونل مشخص می‌کند داده به کدام مسیر منطقی مربوط است؛ این شناسه رمزنگاری یا مدرک هویت کاربر نیست.

در 4G، داده از گوشی و ایستگاه رادیویی وارد هسته شبکه می‌شود و از دروازه‌های خدمت‌رسان و اتصال به شبکه داده، یعنی **S-GW و P-GW**، عبور می‌کند. P-GW نقش مهمی در اتصال به شبکه بیرونی و آدرس نشست دارد. دکل به‌تنهایی مسئول همه تخصیص‌ها و تصمیم‌های ارتباطی نیست. [12]

در 5G، **تابع عبور داده کاربر یا UPF** وظیفه مهمی در عبور داده دارد و **تابع مدیریت نشست یا SMF** نشست را مدیریت و UPF را کنترل می‌کند. بسته به طراحی، UPF می‌تواند نزدیک کاربر یا در نقطه‌ای مرکزی‌تر باشد. پس مسیر همه کاربران الزاماً از یک مرکز ثابت عبور نمی‌کند. [11]

در مدیریت تقلب، تغییر IP ممکن است نتیجه اتصال مجدد یا تغییر نشست باشد. از سوی دیگر، تعداد زیادی مشترک می‌توانند از یک نقطه خروج اینترنت دیده شوند. تطبیق مجاز سوابق مشترک، نشست، زمان و ترجمه آدرس برای فهم این وضعیت لازم است. مکان IP عمومی لزوماً محل دکل یا گوشی نیست. GTP-U هم به‌تنهایی محتوا را رمز نمی‌کند و حفظ نشست در همه جابه‌جایی‌ها تضمین‌شده نیست.

فصل سوم امنیت و تقلب در بستر IP تفسیر نشانه‌ها در FMS

در مدیریت تقلب یا FMS، اطلاعات شبکه به بررسی سوءاستفاده از حساب، خدمت و منابع مالی کمک می‌کند. اما افزایش مصرف، تغییر آدرس یا ورود از VPN می‌تواند علت مجاز هم داشته باشد. تحلیلگر لازم نیست ساختمان داخلی همه تجهیزات را بداند؛ باید بداند هر نشانه چه چیزی را نشان می‌دهد و برای نتیجه‌گیری به چه شاهد دیگری نیاز دارد.

«آسیب‌پذیری» یعنی ضعف قابل سوءاستفاده؛ «حمله» یعنی رفتار آسیب‌زا علیه امنیت یا دسترس‌پذیری؛ و «تقلب» در این بحث، رفتار فریب‌کارانه برای منفعت نامشروع یا تحمیل زیان است. تخلف قراردادی و حمله فنی الزاماً تقلب مالی نیستند. خطای تنظیمات نیز می‌تواند نشانه مشابه ایجاد کند. بنابراین مشاهده، فرضیه و نتیجه تأییدشده باید در گزارش جدا باشند.

۳.۱. آدرس IP چقدر به شناسایی کمک می‌کند

آدرس IP برای رساندن داده به مقصد است و به‌تنهایی شناسنامه یک انسان نیست. یک آدرس ممکن است امروز به یک مشترک و فردا به مشترکی دیگر اختصاص یابد. در خانه یا شرکت نیز چند نفر می‌توانند از یک اتصال و آدرس عمومی مشترک استفاده کنند. در شبکه موبایل، جابه‌جایی کاربر و تغییر اتصال می‌تواند اطلاعات مشاهده‌شده را تغییر دهد؛ هر تغییر آدرس نشانه تخلف نیست.

در «اشتراک آدرس در مقیاس اپراتور» یا CGNAT، حتی چندین مشترک جداگانه می‌توانند هم‌زمان از یک IP عمومی استفاده کنند. تفکیک ارتباط‌ها به شماره پورت و اطلاعات نگاشت وابسته است. پورت را می‌توان شماره‌ای برای تشخیص ارتباط‌های مختلف روی یک دستگاه یا آدرس دانست؛ این شماره با شماره سیم‌کارت یا شناسه شخص یکی نیست.

برای پیگیری یک ارتباط، معمولاً IP عمومی مبدأ، پورت مبدأ، نوع پروتکل مانند TCP یا UDP، زمان دقیق و منطقه زمانی لازم است. در بعضی سامانه‌ها، آدرس و پورت مقصد نیز برای تطبیق دقیق اهمیت دارد. سپس باید

این اطلاعات با سوابق تخصیص آدرس و نگاشت اپراتور تطبیق داده شود. ساعت ناهماهنگ یا ثبت زمان بدون منطقه زمانی می‌تواند تطبیق را اشتباه کند.

موقعیت جغرافیایی منتسب به IP نیز تخمینی است؛ ممکن است محل خروج اپراتور، مرکز داده یا VPN را نشان دهد، نه محل واقعی کاربر. تغییر سریع کشور در گزارش ورود می‌تواند از تغییر مسیر ناشی شود. پایگاه‌های «اعتبار آدرس» که سابقه سوءاستفاده را گزارش می‌کنند نیز ممکن است قدیمی باشند یا کاربران مجازِ یک آدرس مشترک را تحت تأثیر قرار دهند.

حتی تطبیق درست با یک اشتراک، مشخص نمی‌کند چه کسی پشت دستگاه بوده است. در IP، FMS باید در کنار زمان، حساب، دستگاه، رفتار مصرف و سوابق خدمتِ در دسترس و مجاز بررسی شود. آدرس مشترک یا سابقه نامطلوب آن، به‌تنهایی دلیل تقلب یا مبنای کافی مسدودسازی نیست. نتیجه مناسب، بیان شواهد، احتمال‌های جایگزین و سطح اطمینان است.

۳.۲. جعل مبدأ و حمله منع سرویس ترافیک زیاد همیشه حمله نیست

«جعل آدرس مبدأ» یا IP Spoofing یعنی فرستنده روی بسته، آدرسی غیر از مبدأ واقعی بنویسد؛ شبیه درج نشانی نادرست روی پاکت. این کار به‌خودی‌خود به معنی امکان خواندن پاسخ‌ها نیست، چون پاسخ معمولاً به صاحب آدرس جعل‌شده می‌رود. بسیاری از ارتباط‌های معمول برای برقراری نشست به تبادل پاسخ نیاز دارند. کنترل مبدأ در لبه شبکه، خروج بسته‌هایی با آدرس نامجاز را کاهش می‌دهد [14, 15].

در بعضی سرویس‌ها، پاسخ بدون برقراری نشست کامل ارسال می‌شود. اگر مبدأ جعلی باشد، پاسخ به قربانی می‌رسد؛ به این رفتار «بازتاب» می‌گویند. اگر پاسخ از درخواست بزرگ‌تر باشد، «تقویت» نیز رخ می‌دهد. این توضیح برای شناخت سازوکار است؛ مشاهده ترافیک از یک سرور الزاماً به این معنی نیست که صاحب آن، حمله را آغاز کرده است؛ سرور ممکن است ناخواسته واسطه بازتاب باشد.

«منع سرویس» یا DoS یعنی مختل‌کردن دسترسی کاربران معتبر به یک خدمت. اگر فشار از مبدأهای متعدد ایجاد شود، اصطلاح DDoS به کار می‌رود. فشار ممکن است ظرفیت لینک را پر کند یا حافظه، توان پردازش و

ظرفیت پذیرش اتصال را مصرف کند. بنابراین فقط حجم بر حسب مگابیت کافی نیست؛ تعداد بسته، اتصال ناموفق، تأخیر و مصرف منابع نیز اهمیت دارد.

افزایش بازدید یک خبر، انتشار به‌روزرسانی یا خرابی یک برنامه می‌تواند شبیه حمله دیده شود. مقایسه با الگوی عادی، زمان شروع، سرویس‌های درگیر و گزارش چند نقطه کمک می‌کند احتمال‌ها جدا شوند. اگر لینک پیش از رسیدن ترافیک به سازمان پر شده باشد، فایروال داخلی به‌تنهایی مشکل را حل نمی‌کند و همکاری اپراتور بالادست ممکن است لازم شود.

جدول ۳ ــ جعل مبدأ و حمله منع سرویس ترافیک زیاد همیشه حمله نیست

مشاهده	احتمال‌های قابل بررسی	شاهد تکمیلی مفید
مصرف لینک ناگهان زیاد شده	تقاضای واقعی، دانلود گسترده یا حمله حجمی	الگوی گذشته، مقصدها و زمان شروع
حجم متوسط است ولی سرویس پاسخ نمی‌دهد	مشکل برنامه، فشار پردازش یا تعداد زیاد اتصال	وضعیت سرور و نرخ اتصال ناموفق
فقط یک سایت یا مسیر مختل است	مشکل مقصد، مسیریابی یا سیاست دسترسی	مقایسه چند مقصد و چند محل

این جدول ابزار جمع‌آوری شواهد است. محدودکردن شدید همه ترافیک می‌تواند خود باعث قطع خدمت کاربران معتبر شود؛ اقدام دفاعی باید با مسئول فنی و بر اساس اثر واقعی هماهنگ شود.

تفاوت اختلال امنیتی و تقلب مخابراتی

DDoS معمولاً دسترس‌پذیری را هدف می‌گیرد؛ تقلب ممکن است بدون قطع سرویس، هزینه یا منفعت نامشروع ایجاد کند. برای نمونه، سوءاستفاده از حساب تلفن اینترنتی می‌تواند تماس‌های خارج از اختیار صاحب حساب و هزینه غیرعادی بسازد. افزایش تماس خارجی به‌تنهایی اثبات تقلب نیست؛ فعالیت تجاری مجاز یا تغییر تعرفه هم ممکن است توضیح باشد. تطبیق زمان تماس، حساب، مقصد، هزینه و سوابق ثبت تماس، همراه با بررسی مجازبودن مصرف، تصویر کامل‌تری می‌دهد. تکرار تلاش ورود و تغییر دستگاه نیز فقط شاهد تکمیلی‌اند.

۳.۳. مرد میانی در شبکه محلی چرا آدرس درست کافی نیست

وقتی واسطه‌ای ناخواسته بین دو طرف ارتباط قرار بگیرد، وضعیت «مرد میانی» یا MITM ایجاد می‌شود. در شبکه محلی IPv4، سازوکار ARP به دستگاه کمک می‌کند آدرس IP همسایه را به نشانی سخت‌افزاری آن، یعنی MAC، وصل کند. اطلاعات نادرست در این فرایند می‌تواند ترافیک را به دستگاه دیگری هدایت یا ارتباط را قطع کند. این تهدید معمولاً در همان شبکه محلی است؛ پیام ARP از روترهای اینترنت عبور نمی‌کند.

سرویس تخصیص خودکار تنظیمات یا DHCP نیز آدرس، دروازه خروج و گاهی DNS را به دستگاه اعلام می‌کند. پاسخ یک سرویس نامجاز ممکن است دروازه یا DNS اشتباه معرفی کند. DNS نام سرویس، مثل نام یک سایت، را به آدرس قابل استفاده تبدیل می‌کند. تغییر آن می‌تواند دسترسی را مختل یا کاربر را به مقصد نادرست هدایت کند.

دیدن بسته‌ها برابر با خواندن محتوای همه آن‌ها نیست. ارتباط HTTPS با گواهی معتبر معمولاً محتوا را در برابر واسطه محافظت می‌کند؛ اما واسطه هنوز می‌تواند ارتباط را قطع کند یا بخشی از اطلاعات جانبی را ببیند. هشدار گواهی نباید صرفاً برای ادامه کار نادیده گرفته شود. در بررسی رخداد، تغییر DNS یا دروازه، هشدار گواهی و محدودبودن مشکل به یک شبکه، شواهد مفیدی هستند.

تجهیزات مناسب می‌توانند پاسخ‌های DHCP و اطلاعات ARP را کنترل کنند؛ فعال‌سازی آن‌ها به طراحی و آزمون نیاز دارد. در IPv6 سازوکارهای معادل متفاوت‌اند و ARP وجود ندارد. بنابراین نسخه IP و محدوده رخداد باید در گزارش مشخص باشد، بدون اینکه کاربر بررسی‌کننده مجبور به تغییر تنظیمات تخصصی تجهیزات شود.

۳.۴. ربایش مسیر و نشت مسیر مشکل همیشه داخل سازمان نیست

شبکه‌های بزرگ اینترنت مسیر رسیدن به آدرس‌ها را با پروتکل BGP به یکدیگر اعلام می‌کنند. می‌توان آن را تبادل تابلوهای راهنما میان شبکه‌ها دانست. «ربایش مسیر» هنگامی رخ می‌دهد که شبکه‌ای مسیر یک محدوده آدرس را بدون اختیار لازم اعلام کند. «نشت مسیر» یعنی مسیر برخلاف سیاست مورد انتظار به شبکه‌های دیگر منتقل شود؛ این وضعیت می‌تواند نتیجه خطای تنظیمات باشد.

پیامد ممکن است قطع دسترسی، افزایش تأخیر یا عبور ترافیک از مسیر نامطلوب باشد. تغییر مسیر به‌تنهایی رمزنگاری HTTPS یا VPN را از بین نمی‌برد، ولی دسترس‌پذیری و اطلاعات جانبی همچنان مهم‌اند. قطع یک مقصد از چند اپراتور، تغییر هم‌زمان مسیر و اعلام اختلال از سوی صاحب سرویس می‌تواند برای ارجاع فنی ارزشمند باشد؛ از روی یک تأخیر بالا نمی‌توان رباش را اثبات کرد.

سامانه اعتبارسنجی منابع اینترنتی یا RPKI کمک می‌کند مشخص شود کدام شبکه اجازه دارد مبدأ اعلام یک محدوده آدرس باشد. این کنترل همه بخش‌های مسیر را تضمین نمی‌کند و همه نشت‌ها را نمی‌گیرد [16, 17]. وظیفه تفسیر گزارش، ثبت محدوده درگیر و شواهد است؛ تشخیص نهایی به داده مسیریابی و بررسی تیم مسئول نیاز دارد.

۳.۵. بازرسی ترافیک تخلف و حدود حریم خصوصی

«بازرسی عمیق بسته» یا DPI، علاوه بر آدرس و پورت، اطلاعات در دسترس پیام و الگوی جریان را برای شناخت برنامه یا رفتار بررسی می‌کند. کاربرد آن می‌تواند تشخیص تهدید، اندازه‌گیری کیفیت یا اجرای سیاست مصوب باشد. اما نتیجه طبقه‌بندی همیشه قطعی نیست؛ چند سرویس ممکن است زیرساخت مشترک داشته باشند یا با رمزنگاری، اطلاعات کمتری آشکار کنند.

در HTTPS معتبر، محتوای اصلی رمزنگاری می‌شود، ولی معمولاً آدرس مقصد، زمان و حجم ارتباط هنوز قابل مشاهده است. گاهی نام سرویس در آغاز ارتباط دیده می‌شود؛ قابلیت‌های جدید می‌توانند این بخش را نیز پنهان‌تر کنند [23]. رمزنگاری پرس‌وجوی DNS با روش‌هایی مانند DoH یا DoT، مشاهده آن را در مسیر کاهش می‌دهد، اما سرویس‌دهنده DNS همچنان آن را دریافت می‌کند [24, 25]. تشخیص استفاده از VPN هم به معنی توانایی رمزگشایی محتوای آن نیست.

دسترسی بدون مجوز، اخلال عمدی، سرقت داده و سوءاستفاده از اطلاعات می‌توانند مسئولیت قانونی یا قراردادی ایجاد کنند؛ جزئیات به کشور، قرارداد و شرایط رخداد وابسته است. برای VPN یا بازرسی شبکه نمی‌توان یک حکم حقوقی واحد برای همه جهان نوشت. استفاده از ابزار، هدف استفاده و داده پردازش‌شده باید جدا بررسی شوند.

در کار حرفه‌ای، دسترسی به اطلاعات باید مجاز، متناسب با هدف و محدود به نیاز باشد. زمان نگه‌داری، افراد مجاز به مشاهده و روش اشتراک شواهد باید طبق قواعد معتبر سازمان و قانون تعیین شود. آزمایش امنیتی نیز به مجوز و محدوده روشن نیاز دارد. در گزارش اولیه بهتر است «رفتار مشکوک به...» با شواهد نوشته شود؛ اعلام قطعی تخلف، پیش از بررسی لازم، می‌تواند گمراه‌کننده باشد.

فصل چهارم VPN و حدود حفاظت ارتباط

شبکه خصوصی مجازی یا VPN، راهی برای عبور ارتباط از یک مسیر منطقی میان دو نقطه است. در VPNهای امن رایج، داده پیش از عبور از شبکه میانی رمزنگاری می‌شود. کاربرد می‌تواند اتصال کارمند به سازمان، ارتباط دو شعبه یا حفاظت بخشی از ارتباط در شبکه عمومی باشد. برای فهم نتیجه، باید دو سر تونل و مقصد نهایی را از هم تشخیص داد.

۴.۱. سه پرسش اصلی درباره امنیت VPN



شکل ۳ ـ تونل VPN در دروازه پایان می‌یابد؛ رمزنگاری برنامه می‌تواند تا سرور خدمت ادامه داشته باشد.

اول، «طرف مقابل کیست؟» این موضوع احراز هویت است و می‌تواند با گواهی معتبر، کلید یا روش ورود مناسب انجام شود. گواهی در اینجا مدرکی دیجیتال برای اعتبارسنجی هویت سرویس یا طرف ارتباط است. دوم، «چه کسی می‌تواند محتوا را بخواند؟» رمزنگاری، خواندن محتوا را بدون کلید لازم دشوار می‌کند. سوم، «آیا داده در راه تغییر کرده است؟» کنترل یکپارچگی به گیرنده کمک می‌کند دستکاری را تشخیص دهد. داشتن یکی از این قابلیت‌ها، وجود دو مورد دیگر را ثابت نمی‌کند.

روش‌های معتبر VPN این قابلیت‌ها را با هم ترکیب می‌کنند. نام الگوریتم‌هایی مانند AES یا ChaCha20 به‌تنهایی کیفیت کل سرویس را نشان نمی‌دهد؛ حفاظت کلید، به‌روزرسانی، تنظیمات و امنیت دستگاه نیز مهم‌اند. رمز عبور قوی یا احراز هویت چندعاملی، مانند رمز همراه با تأیید برنامه احراز هویت، می‌تواند احتمال ورود غیرمجاز را کاهش دهد، اما دستگاه آلوده یا دسترسی بیش‌ازحد همچنان خطر ایجاد می‌کند.

مرز حفاظت را می‌توان این‌گونه دید: «دستگاه کاربر ← تونل رمزنگاری‌شده ← دروازه VPN ← سرویس مقصد». حفاظت خود VPN در دروازه پایان می‌یابد. اگر از آنجا تا سرویس نهایی نیز HTTPS معتبر برقرار باشد، لایه دیگری از حفاظت محتوا ادامه دارد. سرور VPN لزوماً همه محتوای HTTPS را نمی‌خواند، اما بخشی از مقصدها و اطلاعات ارتباط را می‌بیند؛ پس انتخاب و اعتماد به گرداننده آن مهم است.

تغییر IP عمومی نیز به معنی ناشناس‌شدن نیست. حساب کاربری، کوکی مرورگر، مشخصات دستگاه و اطلاعاتی که خود کاربر وارد می‌کند همچنان می‌توانند او را قابل شناسایی کنند. برای تفسیر رخداد، مشاهده یک IP متعلق به VPN فقط درباره مسیر خروج سرنخ می‌دهد، نه هویت قطعی کاربر یا قصد او.

۴.۲. IPsec به زبان ساده توافق اولیه و انتقال امن داده

IPsec مجموعه‌ای از استانداردها برای حفاظت ارتباط در لایه IP است و در اتصال شعب و دسترسی سازمانی کاربرد دارد [18]. برای فهم آن، دو کار را جدا کنیم: ابتدا دو طرف درباره هویت و شرایط حفاظت توافق می‌کنند؛ سپس داده با همان شرایط منتقل می‌شود. در استقرارهای رایج، IKEv2 کار مذاکره و مدیریت کلید را انجام می‌دهد و ESP داده محافظت‌شده را حمل می‌کند [19, 20].

«توافق امنیتی» یا SA یعنی تنظیمات فعال حفاظت، مانند الگوریتم، کلید و مدت اعتبار؛ برای ارسال و دریافت معمولاً توافق‌های جدا وجود دارد. تعویض دوره‌ای کلید طبیعی است، اما خطای تکراری می‌تواند قطع و وصل بسازد. پیام «مذاکره موفق» نیز به‌تنهایی عبور همه ترافیک را ثابت نمی‌کند.

در «حالت تونلی»، کل بسته داخلی در پوشش محافظت‌شده قرار می‌گیرد و یک آدرس‌دهی بیرونی برای دو سر تونل اضافه می‌شود؛ این حالت در ارتباط شعب رایج است. در «حالت انتقالی»، بیشتر محتوای داخل بسته اصلی محافظت می‌شود و سربرگ IP اصلی باقی می‌ماند. برای کار روزمره، شناخت این تفاوت کافی است؛ نیازی به حفظ اجزای سربرگ نیست.

ترجمه آدرس می‌تواند عبور VPN را تحت تأثیر قرار دهد. سازوکار NAT-T به عبور IPsec از NAT کمک می‌کند، اما هر محدودیت شبکه را حل نمی‌کند. کارکردن اتصال در یک شبکه و شکست آن در شبکه دیگر، پیش از نسبت‌دادن به سوءاستفاده، به بررسی فنی نیاز دارد.

۴.۳. تفاوت گزینه‌های رایج VPN بدون ورود به تنظیمات پیچیده

برای انتخاب VPN، «جدیدتر» یا «سریع‌تر» بودن ادعایی کافی نیست. سازگاری دستگاه‌ها، مدیریت دسترسی، امکان لغو دسترسی، پایداری در شبکه مورد استفاده و کیفیت پشتیبانی باید با هم سنجیده شوند. جدول زیر تفاوت کاربردی گزینه‌های شناخته‌شده را نشان می‌دهد؛ رتبه‌بندی مطلق سرعت یا امنیت نیست.

جدول ۴ ــ تفاوت گزینه‌های رایج VPN بدون ورود به تنظیمات پیچیده

گزینه	کاربرد و ویژگی قابل فهم	نکته‌ای که باید بررسی شود
IKEv2/IPsec	رایج در تجهیزات و دسترسی سازمانی	سازگاری دو طرف و تنظیم هویت و کلید
OpenVPN	انعطاف در سیستم‌عامل و روش انتقال	مدیریت گواهی و کیفیت تنظیمات
WireGuard	طراحی متمرکز بر کلید و تنظیمات رمزنگاری مشخص	مدیریت کاربر و لغو کلید در سامانه مکمل
L2TP/IPsec	موجود در برخی زیرساخت‌های قدیمی	L2TP به‌تنهایی رمزنگاری ندارد؛ حفاظت از IPsec می‌آید
PPTP	گزینه قدیمی با ضعف‌های شناخته‌شده	برای طراحی جدید و اطلاعات حساس مناسب نیست

IKEv2/IPsec در صورت پشتیبانی دو طرف می‌تواند با تغییر شبکه، مانند جابه‌جایی میان وای‌فای و موبایل، بهتر سازگار شود؛ این قابلیت، قطع‌نشدن مطلق را تضمین نمی‌کند. OpenVPN می‌تواند از UDP یا TCP استفاده کند. انتقال روی UDP در بسیاری از مسیرها برای تونل مناسب است؛ انتقال روی TCP ممکن است با بعضی محدودیت‌ها سازگارتر باشد، ولی در مسیر پراتلاف تأخیر بیشتری ایجاد کند [22].

WireGuard هویت همتا را بر اساس کلید می‌شناسد [21]. ورود کاربر با رمز، احراز هویت چندعاملی و مدیریت سازمانی باید در صورت نیاز توسط محصول یا سامانه مدیریت تکمیل شود. همچنین استفاده از پورت رایج یا تغییر ظاهر ارتباط، عبور از همه محدودیت‌های شبکه را تضمین نمی‌کند. در هر گزینه، لغو دسترسی باید در عمل مانع ورود یا ادامه ارتباط غیرمجاز کاربر شود.

۴.۴. همه ترافیک وارد تونل می‌شود مسیر کامل مسیر تفکیکی و نشت

در «تونل کامل» یا Full Tunnel، هدف عبور همه ترافیک تعیین‌شده از VPN است. در «تونل تفکیکی» یا Split Tunnel، فقط ارتباط‌های مشخص، مثلاً مقصدهای سازمانی، وارد VPN می‌شوند و بقیه مستقیم می‌روند. روش تفکیکی می‌تواند بار سازمان را کم کند؛ روش کامل کنترل متمرکزتری می‌دهد، ولی ظرفیت خروجی و سیاست حریم خصوصی اهمیت بیشتری پیدا می‌کند. انتخاب مناسب به نیاز و سیاست مجاز وابسته است.

روشن‌بودن علامت VPN اثبات نمی‌کند هر ارتباطی از آن عبور می‌کند. مسیرهای IPv4 و IPv6، پرس‌وجوی DNS و رفتار هنگام قطع باید جدا بررسی شوند. «نشت DNS» معمولاً به عبور پرس‌وجو از مسیری خلاف انتظار سیاست گفته می‌شود؛ هر DNS خارج از تونل، در همه طراحی‌ها الزاماً خطا نیست. «نشت IPv6» نیز زمانی مطرح است که این ترافیک برخلاف هدف حفاظت، مستقیم خارج شود.

قابلیت قطع اضطراری خروج یا Kill Switch تلاش می‌کند هنگام افت تونل، ترافیک ممنوع را متوقف کند؛ رفتار واقعی آن باید در قطع، تغییر شبکه و بیدارشدن دستگاه آزموده شود. از سوی دیگر، بازنشدن یک سامانه پس از اتصال VPN ممکن است ناشی از DNS یا تداخل آدرس خصوصی شبکه خانه و سازمان باشد. صرفاً فعال‌بودن تونل، رسیدن به مقصد و مجازبودن دسترسی را اثبات نمی‌کند.

۴.۵. چرا داده کوچک می‌رود ولی فایل بزرگ متوقف می‌شود

هر مسیر برای اندازه بسته محدودیتی دارد که «بیشترین اندازه واحد انتقال» یا MTU نامیده می‌شود. MTU در بسیاری از شبکه‌های اترنت ۱۵۰۰ بایت است، اما این مقدار در همه مسیرها یکسان نیست. VPN پوشش اضافی به بسته می‌افزاید؛ بنابراین فضای باقی‌مانده برای داده داخلی کمتر می‌شود. اگر پیام لازم برای اعلام محدودیت مسیر نرسد، ممکن است بسته‌های کوچک عبور کنند و انتقال بزرگ متوقف شود.

در TCP، مقدار دیگری به نام MSS اندازه بخش داده را مشخص می‌کند. تنظیم متناسب آن گاهی به مشکل اندازه کمک می‌کند، اما همه ترافیک، از جمله UDP، را اصلاح نمی‌کند. عدد ثابت مناسب همه VPNها وجود ندارد.

کاهش تصادفی MTU یا دستکاری فایروال بدون اندازه‌گیری می‌تواند مشکل دیگری بسازد؛ بررسی باید توسط مسئول فنی و با امکان بازگشت انجام شود.

سناریوی کاملاً ساختگی: کاربری گزارش می‌کند با VPN وارد سامانه می‌شود و پیام کوچکی در همان برنامه می‌فرستد، اما بارگذاری فایل بزرگ در درصدهای ابتدایی می‌ماند. ثبت مفید شامل زمان دقیق، شبکه مورد استفاده، نام سرویس، اندازه تقریبی فایل و تفاوت نتیجه با اتصال مجاز دیگری است. نباید صرفاً از این نشانه، خرابی VPN یا حمله اعلام کرد؛ محدودیت اندازه بسته یکی از احتمال‌هاست و خطای برنامه، محدودیت فایل و افت مسیر نیز باید بررسی شود.

تیم فنی می‌تواند اندازه بسته قابل عبور، پیام‌های خطای مسیر و وضعیت سرویس را مقایسه کند. پس از اصلاح تأییدشده، همان فایل و شرایط دوباره آزموده می‌شود تا نتیجه قابل مقایسه باشد. این روش، گزارش مبهم «VPN وصل است ولی کار نمی‌کند» را به مشاهده‌ای تبدیل می‌کند که برای عیب‌یابی ارزش عملی دارد.

فصل پنجم فناوری‌های جدیدتر چه چیزی را بهتر می‌کنند

با افزایش خدمات ابری، دورکاری و اتصال شعب، مدیریت مسیرها و کنترل دسترسی اهمیت بیشتری پیدا کرده است. SD-WAN، SRv6 و Zero Trust به این نیازها مربوط‌اند، اما کار یکسانی انجام نمی‌دهند. شناخت آن‌ها به تحلیلگر تقلب کمک می‌کند تغییر مسیر یا دسترسی را با تغییر هویت فرد اشتباه نگیرد.

۵.۱. فناوری SRv6 هدایت ترافیک از نقاط انتخاب‌شده

در مسیریابی معمول، هر روتر بر اساس اطلاعات خود تصمیم می‌گیرد بسته را به کدام همسایه بفرستد. گاهی اپراتور می‌خواهد ترافیک یک خدمت از چند نقطه مشخص عبور کند؛ مثلاً ابتدا به دروازه منطقه‌ای و سپس به مرکز داده معینی برسد. **SRv6** روشی بر بستر IPv6 است که امکان بیان این ترتیب را فراهم می‌کند. [26, 27]

در این روش، شبکه می‌تواند برای بسته مشخص کند به‌ترتیب به کدام نقاط یا عملکردهای تعریف‌شده برسد. لازم نیست نام تمام روترهای بین راه در این فهرست آمده باشد؛ مسیر میان نقاط انتخاب‌شده همچنان از زیرساخت مسیریابی استفاده می‌کند. بنابراین، می‌توان آن را تعیین چند مرحله مهم در مسیر دانست، بدون آنکه همه جزئیات مسیر به‌صورت دستی نوشته شود.

نمونه کاربرد: اپراتور می‌خواهد ترافیک یک خدمت سازمانی از نقطه مشخصی برای اعمال سیاست عبور کند و سپس به مرکز داده برسد. SRv6 می‌تواند این هدایت را انجام دهد.

«مسیر برنامه‌ریزی‌شده» با «کیفیت تضمین‌شده» یکسان نیست. این فناوری به آمادگی تجهیزات و پایش مناسب نیاز دارد. از دید تحلیل تقلب، عبور از دروازه مشترک نیز مهم است: چند کاربر ممکن است در مقصد با IP خروجی همان دروازه دیده شوند. این اشتراک، به‌تنهایی ارتباط میان هویت آن‌ها را ثابت نمی‌کند و ویژگی اختصاصی SRv6 هم نیست.

۵.۲. فناوری SD-WAN انتخاب بهتر میان چند اتصال

یک شعبه ممکن است هم‌زمان به فیبر و اینترنت همراه دسترسی داشته باشد. **SD-WAN** به سازمان کمک می‌کند این اتصال‌ها را با سیاست مشترک مدیریت کند و برای هر نوع ترافیک، مسیر مناسب‌تری انتخاب کند. معیار انتخاب می‌تواند تأخیر، نوسان تأخیر، گم‌شدن بسته‌ها یا قطع ارتباط باشد.

دو اصطلاح در این بحث مهم‌اند: **Underlay** همان اتصال واقعی مانند فیبر یا اینترنت 5G است؛ **Overlay** لایه ارتباطی است که روی این اتصال‌ها ساخته می‌شود و سیاست انتخاب مسیر را اجرا می‌کند. این لایه می‌تواند تونل رمزنگاری‌شده هم داشته باشد. SD-WAN به مسیرهای واقعی زیر خود وابسته است و از یک اتصال ضعیف، ظرفیت نامحدود ایجاد نمی‌کند.

نمونه کاربرد: تماس شعبه از فیبر عبور می‌کند، اما با افت کیفیت، سامانه مسیر پشتیبان را انتخاب می‌کند. اینترنت فیبر ممکن است هنوز وصل باشد. در بعضی طراحی‌ها، این جابه‌جایی IP عمومی خروجی را نیز تغییر می‌دهد؛ بنابراین، تغییر IP همیشه به معنی تغییر فرد یا دستگاه نیست.

اگر محل تقریبی دو IP متفاوت باشد، سامانه ممکن است هشدار «سفر غیرممکن» بدهد؛ یعنی فاصله جغرافیایی دو ورود با فاصله زمانی آن‌ها سازگار به نظر نرسد. تغییر خروجی SD-WAN، VPN یا خطای مکان‌یابی IP می‌تواند توضیح دیگری باشد. باید زمان تغییر مسیر و اطلاعات حساب و دستگاه بررسی شود؛ این هشدار سرنخ است، نه اثبات جابه‌جایی واقعی یا سرقت حساب.

۵.۳. اعتماد صفر ZTNA و SASE دسترسی دقیق‌تر

Zero Trust یا اعتماد صفر یک اصل طراحی امنیتی است: حضور در شبکه داخلی به‌تنهایی برای اعتماد کردن کافی نیست. باید هویت فرد، مجوز او و شرایط مرتبط با دسترسی بررسی شود. نام این رویکرد به معنی رد کردن همه درخواست‌ها نیست؛ منظور این است که مجوز بر اساس شواهد و برای نیاز مشخص صادر شود. [28]

برای مثال، کارمند پس از ورود موفق نباید الزاماً به همه سامانه‌ها دسترسی داشته باشد. احراز هویت چندمرحله‌ای، محدودکردن مجوز و بررسی وضعیت دستگاه می‌توانند بخشی از اجرای این رویکرد باشند. بااین‌حال، ورود موفق

نشان می‌دهد شرایط احراز هویت پذیرفته شده‌اند؛ به‌تنهایی ثابت نمی‌کند صاحب واقعی حساب پشت دستگاه بوده است.

ZTNA یکی از راه‌های فراهم‌کردن چنین دسترسی‌ای است. در نمونه‌ای ساده، پیمانکار فقط به سامانه تیکتینگ مجاز متصل می‌شود و اتصال او مجوز ورود به همه شبکه نیست. VPN هم می‌تواند دسترسی محدود داشته باشد؛ تفاوت نتیجه به طراحی و سیاست بستگی دارد. بنابراین، نام محصول به‌تنهایی نشان نمی‌دهد دسترسی واقعاً ایمن است.

SASE رویکردی برای هماهنگ‌کردن اتصال شبکه و خدمات امنیتی توزیع‌شده است. ممکن است SD-WAN، کنترل دسترسی و حفاظت از استفاده وب را کنار هم قرار دهد. مزیت مورد انتظار، اجرای هماهنگ‌تر سیاست برای شعب و کاربران دورکار است. کیفیت خدمت، محل پردازش داده و دسترس‌پذیری ارائه‌دهنده همچنان اهمیت دارند.

در تحلیل گزارش SASE باید دانست کدام ترافیک واقعاً از خدمت عبور کرده و ثبت شده است. نبود رویداد، به‌تنهایی نبود فعالیت را ثابت نمی‌کند؛ بخشی از ترافیک ممکن است مسیر دیگری داشته باشد. شمارش رکوردها نیز الزاماً شمارش کاربران یا تقلب‌ها نیست. این ابزارها شواهد بیشتری فراهم می‌کنند، اما تفسیر درست به شناخت محل ثبت و سیاست فعال وابسته است.

مقایسه کاربردها

جدول ۵ ـ اعتماد صفر ZTNA و SASE دسترسی دقیق‌تر

نام	مسئله‌ای که دنبال می‌کند	نکته مهم در بررسی رویداد
SRv6	هدایت ترافیک از نقاط انتخاب‌شده	IP یک دروازه مشترک، هویت مشترک را ثابت نمی‌کند.
SD-WAN	مدیریت چند اتصال و انتخاب مسیر	تغییر خروجی می‌تواند هشدار مکانی کاذب ایجاد کند.
Zero Trust	تصمیم دسترسی بر پایه هویت و شرایط	ورود موفق، هویت شخص واقعی را به‌تنهایی ثابت نمی‌کند.
ZTNA	دسترسی محدود به سامانه مشخص	رد درخواست ممکن است نتیجه سیاست مجوز باشد.
SASE	هماهنگی اتصال و خدمات امنیتی	گزارش فقط درباره ترافیک قابل‌مشاهده آن خدمت است.

پیوست راهنمای تحلیل رخداد در مدیریت تقلب

۱. از کیفیت لاگ تا تصمیم قابل دفاع

در FMS یا **مدیریت تقلب**، شناخت IP کمک می‌کند رفتارهای مرتبط را پیدا کنیم، احتمال‌های مختلف را بسنجیم و برای بررسی بعدی درخواست دقیقی بنویسیم. قرار نیست از روی یک نشانی، هویت فرد یا وقوع تقلب را قطعی اعلام کنیم. مسیر مناسب چنین است: **بررسی کیفیت داده، تشخیص نشانه، ساختن فرضیه، تطبیق شواهد و ارجاع مطابق سیاست سازمان**.

سه مفهوم را جدا نگه دارید. **رویداد** چیزی است که سامانه ثبت کرده، مانند ورود موفق یا شروع تماس. **مورد مشکوک** رویداد یا الگویی است که نیاز به بررسی دارد. **پرونده تأییدشده تقلب** به شواهد کافی و فرایند تصمیم‌گیری مصوب نیاز دارد؛ صرف فعال‌شدن یک قاعده، آن را تأیید نمی‌کند. سطح اطمینان را با دلیل بنویسید؛ مثلاً «دو منبع مستقل هم‌خوان‌اند، اما نگاشت نشست در دسترس نیست». امتیاز عددی بدون روش معتبر نسازید.

پیش از تحلیل، مشخص کنید لاگ از کدام سامانه آمده، چه چیزی را ثبت می‌کند و چه چیزهایی خارج از پوشش آن است. زمان وقوع با زمان دریافت در FMS ممکن است فرق کند. منطقه زمانی، دقت ساعت، تأخیر ارسال، تکراری‌بودن رکوردها و نمونه‌برداری را بررسی کنید. نبود یک رویداد در لاگ ناقص، نبود آن رویداد در واقعیت را ثابت نمی‌کند. اگر داده از واسط یا پراکسی می‌آید، روشن کنید IP ثبت‌شده متعلق به کاربر است یا همان واسط؛ اعتبار اطلاعات ارسال‌شده توسط واسط نیز باید معلوم باشد.

۲. چهار سناریوی بررسی تقلب

تمام شناسه‌ها، زمان‌ها و نشانی‌های مثال‌های زیر ساختگی‌اند و اطلاعات شخصی واقعی ندارند. محدوده‌های 198.51.100.0/24، 192.0.2.0/24 و 203.0.113.0/24 برای مستندسازی هستند.

سناریوی اول چند حساب یک IP عمومی مشترک دارند

قاعده‌ای هشدار می‌دهد که چند حساب در یک بازه کوتاه از 198.51.100.27 وارد شده‌اند. فرضیه تبانی قابل بررسی است، اما اشتراک IP به‌تنهایی آن را ثابت نمی‌کند. CGNAT اپراتور، اینترنت شرکت یا هتل و خروجی مشترک VPN می‌توانند چند کاربر مستقل را با یک IP عمومی نشان دهند. در جهت مقابل، چند IP متفاوت نیز استقلال کاربران را ثابت نمی‌کند. [6]

برای یک ارتباط مشخص، زمان دقیق و منطقه زمانی، IP و پورت مبدأ عمومی، پروتکل و مقصد اهمیت دارند. برای مثال، 198.51.100.27:43122 به مقصد 192.0.2.80:443 با TCP در 09:15:20 UTC از ذکر IP تنها دقیق‌تر است. تطبیق با مشترک یا نشست، در صورت مجازبودن، به نگاشت معتبر NAT و سامانه‌های مربوط نیاز دارد. اطلاعات لازم به معماری و شیوه ثبت اپراتور وابسته است؛ اگر پورت در لاگ وجود ندارد، آن را حدس نزنید.

سپس الگوی حساب‌ها، ترتیب رویدادها و سایر شواهد مجاز را کنار هم بگذارید. استفاده از یک IP می‌تواند فقط نشان‌دهنده خروجی اینترنت مشترک باشد. جمع‌بندی مناسب: «اشتراک IP مشاهده شده؛ ارتباط میان صاحبان حساب‌ها تأیید نشده؛ برای بررسی بیشتر، نگاشت نشست و شواهد رفتاری لازم است.»

سناریوی دوم ورود از دو کشور با فاصله زمانی کم

حساب ساختگی «الف» در 10:00 UTC وارد می‌شود و پنج دقیقه بعد ورود موفق دیگری با IP منتسب به کشور دیگری دیده می‌شود. چنین الگویی می‌تواند نشانه تصاحب حساب باشد، اما ابتدا مطمئن شوید دو رکورد، ورود واقعی و موفق‌اند؛ یک درخواست ناموفق، تمدید نشست یا دریافت دیرهنگام لاگ معنای متفاوتی دارد.

مکان‌یابی IP معمولاً مکان تقریبی خروجی شبکه را برآورد می‌کند، نه موقعیت قطعی شخص. پایگاه مکان‌یابی ممکن است قدیمی باشد. VPN، پراکسی، شبکه سازمانی و نحوه خروج ترافیک هنگام رومینگ همراه نیز می‌توانند ظاهر مکان را تغییر دهند. ASN به شناخت شبکه اعلام‌کننده نشانی کمک می‌کند؛ نام شبکه به‌تنهایی صاحب حساب یا محل حضور او را اثبات نمی‌کند.

زمان رویدادها را یکسان‌سازی کنید و استمرار یا تغییر نشست، شناسه‌های مجاز دستگاه، تغییر اطلاعات حساب و اقدامات حساس پس از ورود را بررسی کنید. درخواست توضیح از مشترک فقط از مسیر مصوب انجام شود. اگر

تغییر کشور همراه با تغییر رمز و اقدام مالی غیرمعمول باشد، ظن قوی‌تر می‌شود؛ هر نشانه همچنان باید در زمینه خودش تفسیر شود. نتیجه نمونه: «الگوی ورود غیرمعمول است؛ جابه‌جایی واقعی اثبات نشده؛ بررسی نشست و اقدام‌های بعد از ورود لازم است.»

سناریوی سوم تماس‌های سریع به مقصدهای بین‌المللی گران

برای یک حساب تلفنی ساختگی، تعداد تماس‌های خروجی در یک بازه کوتاه افزایش یافته و مقصدها طبق اطلاعات تعرفه‌ای معتبر پرهزینه‌اند. این الگو می‌تواند با استفاده مشروع، فعالیت مجاز مرکز تماس، پیکربندی اشتباه یا سوءاستفاده از حساب یا سامانه تلفنی مرتبط باشد. زیادبودن تعداد تماس یا گران‌بودن مقصد، به‌تنهایی تقلب را تأیید نمی‌کند.

در CDR، روشن کنید هر رکورد نشان‌دهنده تلاش تماس است یا تماس پاسخ‌داده‌شده. زمان شروع، زمان پاسخ، زمان پایان، مدت قابل‌محاسبه و هزینه، بسته به سامانه معنای مشخصی دارند. هزینه تخمینی را با مبلغ نهایی صورتحساب یکسان نگیرید. یک تماس ممکن است در چند تجهیز یا چند بخش مسیر، چند رکورد داشته باشد؛ جمع ساده آن‌ها می‌تواند تعداد یا هزینه را بیشتر از واقع نشان دهد.

سپس حساب احراز هویت‌شده، مسیر خروج، اطلاعات سیگنالینگ SIP و سابقه ثبت یا ورود را در محدوده مجاز تطبیق دهید. **Caller ID نمایش‌داده‌شده، به‌تنهایی هویت تأییدشده تماس‌گیرنده نیست.** IP مبدأ در یک لاگ SIP ممکن است متعلق به تجهیز مرزی مدیریت تماس یا SBC، یا یک پراکسی باشد؛ محل ثبت را مشخص کنید. برای تماس‌های هم‌زمان، هم‌پوشانی زمان آغاز و پایان را بررسی کنید؛ تعداد زیاد تلاش در یک دقیقه، الزاماً هم‌زمانی زیاد نیست.

جمع‌بندی نمونه: «تغییر محسوس الگوی تماس و هزینه محتمل مشاهده شده؛ مشروع‌بودن مصرف و وضعیت امنیت حساب روشن نیست؛ تطبیق CDR با سیگنالینگ و درخواست بررسی طبق سیاست سازمان لازم است.» تصمیم مهار یا محدودسازی باید با اختیار و فرایند مصوب انجام شود.

سناریوی چهارم جهش ظاهری مصرف ناشی از لاگ‌هاست

نمودار FMS جهش ناگهانی تعداد نشست یا مصرف را نشان می‌دهد. پیش از نسبت‌دادن آن به سوءاستفاده، زمان وقوع و زمان ورود داده را جدا کنید. ممکن است سامانه پس از قطع ارتباط، لاگ چند ساعت قبل را یک‌جا فرستاده باشد. اگر نمودار بر زمان دریافت ساخته شده باشد، این ورود دسته‌ای شبیه افزایش ناگهانی فعالیت دیده می‌شود.

احتمال ارسال دوباره رکوردها را نیز بررسی کنید. شناسه رکورد، منبع، شناسه نشست و شماره ترتیب، در صورت وجود، به شناسایی تکرار کمک می‌کنند. صرف برابر بودن IP و زمان نزدیک، دلیل کافی برای حذف رکورد نیست؛ دو ارتباط مشروع می‌توانند چنین ویژگی‌هایی داشته باشند. اگر داده چند سامانه را ترکیب می‌کنید، مشخص کنید آیا هرکدام همان ارتباط را ثبت کرده‌اند یا مرحله متفاوتی را.

در شمارنده مصرف، روشن کنید مقدار ثبت‌شده تجمعی است یا مصرف همان بازه. فاصله نمونه‌برداری، صفرشدن شمارنده و تفاوت واحد بایت با بیت نیز اهمیت دارند. خروجی را با منبع معتبر دیگری مقایسه کنید. نتیجه نمونه: «بخش عمده جهش با ورود دیرهنگام رکوردها هم‌زمان است؛ افزایش واقعی مصرف هنوز تأیید نشده؛ بازسازی نمودار بر مبنای زمان وقوع و بررسی تکرار لازم است.» وجود مشکل داده، احتمال تخلف مستقل را خودکار رد نمی‌کند.

۳. الگوی ثبت پرونده و واژه‌نامه

یادداشت پرونده باید برای تحلیلگر بعدی قابل بازسازی باشد. مدارک را در محل مجاز نگه دارید و به شناسه آن‌ها ارجاع دهید. اطلاعات شخصی اضافی، رمز، کلید و محتوای غیرضروری ارتباط را وارد گزارش عمومی نکنید. درخواست داده و اقدام روی حساب باید با سطح دسترسی، سیاست نگه‌داری و فرایند سازمان سازگار باشد.

- **مشاهده:** چه قاعده یا نشانه‌ای فعال شده؛ کدام سرویس و حساب مستعار؛ بازه زمانی و منطقه زمانی.
- **شواهد و کیفیت:** منبع داده، شناسه رکورد و نشست، IP و پورت و پروتکل لازم؛ دقت ساعت، تأخیر یا تکرار احتمالی.
- **دانسته‌ها:** چه نکاتی با مدرک تأیید شده‌اند و ارتباط هر مدرک با ادعا چیست.

- **نادانسته‌ها و فرضیه‌ها:** چه اطلاعاتی نداریم؛ توضیح‌های مشروع و مشکوک محتمل کدام‌اند.
- **درخواست بعدی و تصمیم:** چه داده‌ای از چه مرجع مجازی لازم است؛ مسئول پیگیری؛ دلیل ارجاع و وضعیت فعلی پرونده.

از عبارت‌هایی مانند «تقلب قطعی» برای پرونده در حال بررسی استفاده نکنید. اگر شواهد ناکافی است، همین محدودیت را بنویسید. اگر مورد مشروع تشخیص داده شد، علت فعال‌شدن قاعده را ثبت کنید تا بازبینی آن بر پایه نمونه واقعی انجام شود.

جدول ۶ ـ الگوی ثبت پرونده و واژه‌نامه

اصطلاح	معنی در بررسی تقلب
پروتکل IP	قواعد ارسال بسته با استفاده از نشانی‌های مبدأ و مقصد.
نشانی IP	نشانی یک رابط شبکه؛ سرنخ ارتباط است، نه شناسه قطعی انسان.
پورت	شماره‌ای که همراه IP و پروتکل، ارتباط را دقیق‌تر مشخص می‌کند.
پروتکل	قواعد ارتباط، مانند TCP یا UDP؛ بخشی از مشخصات رکورد ارتباطی.
Timestamp	زمان ثبت‌شده؛ باید معلوم باشد زمان وقوع است یا دریافت، با چه منطقه زمانی.
Session	نشست؛ مجموعه ارتباطات مرتبط طبق تعریف همان سامانه.
CGNAT	اشتراک IPv4 عمومی میان مشترکان با ترجمه نشانی در شبکه اپراتور.
ASN	شماره یک سامانه مستقل مسیریابی؛ برای شناخت شبکه مرتبط با IP مفید است.
Proxy / VPN	واسط یا تونلی که می‌تواند IP دیده‌شده را تغییر دهد؛ استفاده از آن اثبات تقلب نیست.
CDR	رکورد جزئیات تماس یا مصرف؛ معنای فیلدها به سامانه تولیدکننده وابسته است.
SIP	پروتکل سیگنالینگ برای ایجاد و مدیریت نشست‌هایی مانند تماس صوتی.
Caller ID	شناسه اعلام‌شده تماس‌گیرنده؛ به‌تنهایی هویت تأییدشده نیست.
Correlation	مرتبط‌کردن رکوردها با زمان، نشست یا شواهد مشترک؛ به‌خودی‌خود اثبات علت نیست.
False Positive	مورد مشروعی که قاعده آن را به‌اشتباه مشکوک علامت زده است.
احراز هویت	بررسی ادعای هویت با سازوکار مشخص؛ به‌تنهایی مشروع‌بودن همه اقدام‌ها را ثابت نمی‌کند.

منابع و یادداشت ارجاع

ارجاع‌های شماره‌دار متن به منابع زیر اشاره دارند. در اجرای واقعی، نسخه و Release مشخصات 3GPP، اصلاحیه‌های RFC و راهنمای نسخه محصول باید بررسی شوند. مثال‌های ظرفیت و زمان، در صورت نداشتن منبع اندازه‌گیری، آموزشی و وابسته به فرض‌های ذکرشده‌اند. محدوده‌های آدرس مستندسازی برای استفاده در شبکه عملیاتی عمومی نیستند.

یادداشت بررسی منابع عنوان و روابط به‌روزرسانی تعدادی از RFCها با متادیتای رسمی مخزن IETF Tools تطبیق داده شده است؛ از جمله مرجع TLS 1.3 در RFC 9846 به‌جای اکتفا به RFC 8446. دسترسی مستقیم محیط تدوین به همه صفحات رسمی فراهم نبود؛ بنابراین این گزارش ادعای بررسی زنده تمام استانداردها، همه اصلاحیه‌ها یا ممیزی یک شبکه واقعی را ندارد.

[1] RFC 791. Internet Protocol
https://www.rfc-editor.org/rfc/rfc791

[2] RFC 8200. Internet Protocol, Version 6 (IPv6) Specification
https://www.rfc-editor.org/rfc/rfc8200

[3] RFC 4632. Classless Inter-domain Routing (CIDR)
https://www.rfc-editor.org/rfc/rfc4632

[4] RFC 1918. Address Allocation for Private Internets
https://www.rfc-editor.org/rfc/rfc1918

[5] RFC 6598. IANA-Reserved IPv4 Prefix for Shared Address Space
https://www.rfc-editor.org/rfc/rfc6598

[6] RFC 6888. Common Requirements for Carrier-Grade NATs (CGNs)
https://www.rfc-editor.org/rfc/rfc6888

[7] RFC 8201. Path MTU Discovery for IP version 6
https://www.rfc-editor.org/rfc/rfc8201

[8] RFC 4271. A Border Gateway Protocol 4 (BGP-4)
https://www.rfc-editor.org/rfc/rfc4271

[9] RFC 2474. Definition of the Differentiated Services Field
https://www.rfc-editor.org/rfc/rfc2474

[10] RFC 4364. BGP/MPLS IP Virtual Private Networks (VPNs)
https://www.rfc-editor.org/rfc/rfc4364

[11] 3GPP TS 23.501. System architecture for the 5G System (5GS)
https://www.3gpp.org/ftp/Specs/archive/23_series/23.501/

[12] 3GPP TS 23.401. GPRS enhancements for E-UTRAN access
https://www.3gpp.org/ftp/Specs/archive/23_series/23.401/

[13] 3GPP TS 23.228. IP Multimedia Subsystem (IMS); Stage 2
https://www.3gpp.org/ftp/Specs/archive/23_series/23.228/

[14] RFC 2827 / BCP 38. Network Ingress Filtering
https://www.rfc-editor.org/rfc/rfc2827

[15] RFC 3704. Ingress Filtering for Multihomed Networks
https://www.rfc-editor.org/rfc/rfc3704

[16] RFC 6811. BGP Prefix Origin Validation
https://www.rfc-editor.org/rfc/rfc6811

[17] RFC 7454 / BCP 194. BGP Operations and Security
https://www.rfc-editor.org/rfc/rfc7454

[18] RFC 4301. Security Architecture for the Internet Protocol
https://www.rfc-editor.org/rfc/rfc4301

[19] RFC 4303. IP Encapsulating Security Payload (ESP)
https://www.rfc-editor.org/rfc/rfc4303

[20] RFC 7296. Internet Key Exchange Protocol Version 2 (IKEv2)
https://www.rfc-editor.org/rfc/rfc7296

[21] WireGuard. Protocol and Cryptography
https://www.wireguard.com/protocol/

[22] OpenVPN. OpenVPN 2.6 Reference Manual
https://openvpn.net/community-resources/reference-manual-for-openvpn-2-6/

[23] RFC 9846. The Transport Layer Security (TLS) Protocol Version 1.3; obsoletes RFC 8446
https://www.rfc-editor.org/rfc/rfc9846

[24] RFC 7858. Specification for DNS over Transport Layer Security (TLS)
https://www.rfc-editor.org/rfc/rfc7858

[25] RFC 8484. DNS Queries over HTTPS (DoH)
https://www.rfc-editor.org/rfc/rfc8484

[26] RFC 8402. Segment Routing Architecture
https://www.rfc-editor.org/rfc/rfc8402

[27] RFC 8754. IPv6 Segment Routing Header (SRH)
https://www.rfc-editor.org/rfc/rfc8754

[28] NIST SP 800-207. Zero Trust Architecture
https://doi.org/10.6028/NIST.SP.800-207